

Pacote para Revisão Jurídica

Bivaque Community — MVP Manaus

Data de envio: 2026-08-25

Remetente: Juan (fundador)

Tipo: adequação LGPD + textos publicáveis de privacidade/conduta

Documento operacional para revisão jurídica. Os anexos internos não devem ser publicados no site nem expostos como termo aceito pelo membro.

PACOTE PARA REVISÃO JURÍDICA — BIVAQUE COMMUNITY

Data de envio: 2026-08-25

Remetente: Juan (fundador) · Produto: Bivaque Community (MVP piloto Manaus)

Tipo de revisão: adequação LGPD + estrutura de privacidade/conduta para lançamento

1. RESUMO EM 1 PÁGINA (LEIA PRIMEIRO)

O Bivaque Community é uma comunidade digital privada, com verificação de elegibilidade por meio do Portal da Transparência (órgão federal), voltada a militares federais, veteranos e pensionistas. Piloto: Manaus.

O código do MVP está pronto (gate de qualidade verde, 1042/1042 testes de banco verdes, E2E majoritariamente verde). O que impede o lançamento são exclusivamente decisões externas/humanas, e estas se dividem em dois blocos:

- Decisões que o DONO toma (R3): afiliação militar declarada, manter ou suprimir WhatsApp/Asaas no MVP, resolver 9 falhas do E2E.
- Decisões que VOCÊ (advogado) toma ou co-assina: quem é o controlador dos dados, redação publicável de privacidade e conduta, base legal para os terceiros que recebem dado (Resend, Sentry, PostHog, IA, possivelmente WhatsApp/Asaas), e governança LGPD aplicável ao uso de IA no produto.

Este pacote contém:

- 1) este resumo;
- 2) estado atual dos textos que vão ao aceite do membro (rascunhos originais anexos no repositório);
- 3) fatos do produto que sustentam as escolhas de texto;
- 4) 8 decisões humanas abertas que precisam de parecer;
- 5) red flags já identificados;
- 6) referências normativas da ANPD.

Os textos-fonte em rascunho (docs/legal/PRIVACIDADE.md e docs/legal/CODIGO_DE_CONDUTA.md) e o dossiê operacional interno (docs/legal/REVISAO_LANCAMENTO.md) ficam no repositório do produto para que a revisão seja feita diretamente no documento, com controle de versão — não em cópias coladas aqui.

2. ESTADO ATUAL DOS TEXTOS QUE IRÃO AO ACEITE DO MEMBRO

2.1. docs/legal/PRIVACIDADE.md (108 linhas)

- Abre declarando que está em rascunho e precisa de revisão jurídica.
- Contém placeholders em aberto: nome do controlador, endereço, canal oficial, encarregado (DPO ou dispensa fundamentada).
- Menciona afiliação militar declarada como opcional, mas o contrato interno proíbe persistir OM enquanto o ADR não estiver aprovado.
- Lista de terceiros precisa separar (a) ativos no MVP e (b) planejados/condicionais.

2.2. docs/legal/CODIGO_DE_CONDUTA.md (74 linhas)

- Abre declarando que precisa de revisão do dono.
- Precisa fundamentar três ações operacionais: denúncia, ocultação, suspensão de conta (e respectivo recurso).
- Hoje não há texto assinado pelo dono justificando a gradação de sanção.

3. FATOS DO PRODUTO QUE DEFINEM O TRATAMENTO DE DADOS

Elegibilidade e entrada

- Público: militar federal, veterano ou pensionista, validados por consulta ao Portal da Transparência via CPF.
- CPF é enviado server-side ao Portal; o resultado é persistido sem o número em texto claro (apenas o identificador interno de verificação).
- Há caminho de exceção por documento (TTL curto, 7 dias), quando o Portal recusa ou está indisponível.
- Dependentes entram por convite do titular, com conta própria e e-mail alvo conferido no aceite.
- Membros aceitam: política de privacidade, código de conduta, e registram versão do aceite com data.

Comunidade e conteúdo

- Membros publicam: posts, comentários, pedidos de indicação, respostas, eventos, RSVPs, participação em grupos.
- Tudo isso fica escopado por comunidade/cidade; a cidade é o alcance máximo, não uma sala de chat (decisão interna D48).
- Denúncias e moderação geram registros que podem sobreviver à exclusão de conta (risco de incidente com conteúdo litigioso).

Terceiros com acesso a dado

- Resend: envio de e-mail transacional (convite, aprovação, magic link).
- Sentry: observabilidade de erros — pacote passa por pii-scrub (CPF, e-mail, telefone removidos antes de chegar ao provedor).
- PostHog: métrica de produto (status: definido, ainda sem decisão LGPD).
- WhatsApp: decisão recente do fundador = fora do MVP automático; pode

ficar só como suporte manual. Se ficar só suporte manual, NÃO pode aparecer como canal normal de notificação na política.

- Asaas: vitrine paga — exige CNPJ. Hoje o fundador NÃO tem CNPJ contratado, portanto Asaas NÃO pode entrar como canal ativo no MVP sem prévia decisão e abertura de empresa.
- IA de curadoria do guia (interna D49): pendente de governança LGPD.

Infraestrutura e retenção

- Servidor: Vercel + Supabase, em região ainda não declarada na política (definir e incluir no texto).
- Domínio verificado para envio: stoqio.com.br.
- Sem staging: erro de migração atinge produção direto (decisão interna aceita, vale registrar na política de risco).
- pgTAP: 1042/1042. RLS: fechamento de auditoria em 2026-08-22 (sem gaps críticos). Cinco funções residuais com auth.uid() interno + service_role grant, sem uso em runtime hoje (débitos técnicos, não bloqueiam).

4. AS 8 DECISÕES HUMANAS PENDENTES (PARECER JURÍDICO SOLICITADO)

5. RED FLAGS JÁ IDENTIFICADOS NOS TEXTOS

1. PRIVACIDADE.md ainda declara que precisa de revisão jurídica.
2. CODIGO_DE_CONDOTA.md ainda declara que precisa de revisão do dono.
3. PRIVACIDADE.md trata afiliação declarada como opcional, mas o contrato interno (AGENTS.md §205) proíbe persistir OM enquanto o ADR estiver em "proposed". Precisamos ou (a) condicionar textualmente OU (b) fechar o ADR antes de publicar.
4. Lista de terceiros na política não distingue ativos no MVP de planejados/condicionais.
5. WhatsApp foi retirado do MVP automático nesta semana; se permanecer apenas como suporte manual, não pode estar descrito como canal normal de notificação.
6. PostHog, IA de curadoria e Asaas exigem governança própria ANTES de qualquer ativação.
7. Direitos do titular: o texto deve confirmar o fluxo REAL de atendimento e se há exigência de tentativa prévia pelo canal oficial antes de peticionar à ANPD.
8. Regra "uso contínuo = aceite": precisa ser revisada para mudanças MATERIAIS de tratamento ou de conduta — não pode renovar aceite automaticamente para alterações substanciais.

6. PERGUNTAS OBJETIVAS PARA O PARECER

Por favor, responder com clareza em cada item:

1. CONTROLADOR: Qual a recomendação de estrutura jurídica da pessoa jurídica (ou pessoa física) que deverá figurar como controladora no texto publicável? Dado o histórico do fundador (militar da ativa, restrição do Art. 29 da Lei 6.880/80), há caminho recomendado? (Observação interna: esta é a origem do bloqueio do CNPJ.)
2. BASE LEGAL POR FINALIDADE: para cada uma das finalidades abaixo, qual a base legal recomendada (consentimento, execução de contrato, interesse legítimo, obrigação legal)?
 - a) verificação de elegibilidade (CPF + Portal);
 - b) operação da conta (login, magic link, Google);
 - c) comunidade (posts, comentários, eventos, RSVP);
 - d) moderação e sanção;
 - e) convite de dependente;
 - f) comunicação transacional por e-mail (Resend);
 - g) observabilidade técnica (Sentry — dado pii-scrubbed);
 - h) métrica de produto (PostHog — quando entrar);
 - i) IA de curadoria (quando entrar);
 - j) WhatsApp (se mantido);
 - k) Asaas/cobrança (se mantido).
3. DPO/ENCARREGADO: a ANPD admite dispensa formal de encarregado para agentes de pequeno porte? Em que condições? Qual o texto padrão recomendado para registrar dispensa fundamentada?
4. RETENÇÃO: quais os prazos sugeridos para:
 - a) logs de auditoria de moderação?
 - b) pedidos de indicação (incluindo após encerramento de conta)?
 - c) registros de incidente?
 - d) dados de conta após exclusão (contas dependentes, etc.)?
5. INCIDENTE: sugestão de texto para o procedimento interno de resposta a incidente, incluindo prazo de comunicação à ANPD (Art. 48 LGPD: "razoável" — qual a parametrização recomendada?) e fluxo de comunicação aos titulares afetados.
6. SUSPENSÃO E SANÇÃO: o código de conduta atual precisa ancorar gradação (advertência, ocultação, suspensão, exclusão). Qual a estrutura recomendada de modo a sobreviver a contestação judicial?
7. SUB-PROCESSADORES: a lista atual (Resend, Sentry, Supabase, Vercel, PostHog, eventualmente WhatsApp/Asaas) é suficiente? Há provedores implícitos que precisamos declarar (ex.: provedor de DNS, transportadora de e-mail)?

8. TRANSFERÊNCIA INTERNACIONAL: Supabase pode estar em região não nacional; há decisão a documentar quanto a país-sede e eventual cláusula contratual padrão (SCCs)?

7. REFERÊNCIAS NORMATIVAS DISPONIBILIZADAS

- ANPD — Guia orientativo sobre segurança da informação para agentes de tratamento de pequeno porte

<https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/guia-orientativo-sobre-seguranca-da-informacao-para-agentes-de-tratamento-de-pequeno-porte>

- ANPD — Direitos dos titulares

<https://www.gov.br/anpd/pt-br/assuntos/titular-de-dados-1/direito-dos-titulares>

- ANPD — Resolução CD/ANPD nº 2/2022

https://www.gov.br/anpd/pt-br/aceso-a-informacao/institucional/atos-normativos/regulamentacoes_anpd/resolucao-cd-anpd-no-2-de-27-de-janeiro-de-2022

- Lei nº 13.709/2018 (LGPD)

- Lei nº 6.880/1980 (Estatuto dos Militares, Art. 29) — contexto do fundador, não do produto.

8. ENTREGA E PRÓXIMOS PASSOS

- Prazo desejado para devolutiva: a combinar conforme complexidade.
- Formato de devolutiva preferido: marcações no Markdown devolvido + memorando curto respondendo às 8 perguntas da Seção 6.
- Em caso de dúvida sobre intenção de produto, prefiro pergunta explícita em vez de suposição.

9. ANEXOS INTERNOS (somente leitura — NÃO publicar no site)

Texto-fonte a ser revisado (no repositório, em docs/legal/):

- PRIVACIDADE.md (108 linhas) — política em rascunho
- CODIGO_DE_CONDUTA.md (74 linhas) — conduta em rascunho

Contexto operacional interno (no repositório):

- docs/agents/AUDIT_LANCAMENTO-2026-08-25.md — auditoria completa de prontidão (15.8 KB), incluindo caminho crítico para abrir o piloto.
- docs/legal/REVISAO_LANCAMENTO.md — dossiê interno (6.3 KB) que coordena esta revisão. NÃO substituir os textos publicáveis por este dossiê; NÃO expor em rota pública.

Recomendação: ler PRIVACIDADE.md e CODIGO_DE_CONDUTA.md diretamente no repositório, com controle de versão, e devolver os arquivos marcados — não cópias coladas neste e-mail.